

Chapitre 8

Étude de cas — cybermenaces et sécurité de l'information

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — Au-delà du risque cyber : une typologie de la sécurité de l'information

- (a) Le cours affirme que « la sécurité de l'information ne se réduit pas au risque cyber : un rapport d'audit oublié dans un train, une pièce jointe envoyée par erreur au mauvais destinataire, ou un document confidentiel jeté négligemment à la corbeille constituent tout autant des incidents de sécurité de l'information que le piratage d'un serveur », en citant une étude McAfee de 2017 selon laquelle « 43 % des fuites de données sont d'origine interne, la moitié d'entre elles étant non intentionnelles ». Expliquer précisément pourquoi une pièce jointe mal adressée relève de la même catégorie de risque qu'un piratage informatique au sens du cours, alors que l'une résulte d'une intention malveillante et l'autre d'une simple erreur. Que signifie concrètement le fait que la moitié des 43 % de fuites internes soit « non intentionnelle » pour le type de contrôle (comportemental ou technique) le plus pertinent face à ce sous-ensemble particulier ?
- (b) Le cours répartit les risques de sécurité de l'information « selon deux axes : la cause (interne, y compris prestataires et consultants sur site; ou externe, y compris les tiers) et la nature de l'incident (vol ou corruption intentionnelle des données; perte ou divulgation involontaire) », ce croisement produisant quatre quadrants : « piratage et ingénierie sociale (externe/vol), catastrophes et défaillances de tiers (externe/perte), vol par un employé ou départ mal maîtrisé (interne/vol), et pertes de sauvegardes ou erreurs d'envoi (interne/perte) ». En vous appuyant sur l'étude de cas des fuites emblématiques, classer précisément chacun des quatre événements suivants dans le quadrant qui lui correspond, en justifiant chaque classement : les Paradise Papers (fuite de 1,4 téraoctet du cabinet Appleby) ; la fuite suspectée d'un employé de l'IRS ayant permis à ProPublica de publier des taux d'imposition ; le vol de clés privées ayant coûté 55 millions de dollars à la plateforme bZx (2021) ; le vol de clés privées ayant coûté 139,2 millions de dollars à l'échange BXH (2021), « ce dernier cas illustrant une possible complicité interne ».
- (c) Le cours identifie trois référentiels : le NIST CSF, « organisé autour de cinq fonctions — identifier, protéger, détecter, répondre, récupérer » ; les contrôles critiques du CIS, « une liste de 18 contrôles priorités régulièrement mise à jour par une coalition d'experts » ; et l'ISO/IEC 27001, qui « certifie l'existence d'un système de management de la sécurité de l'information (SMSI) fondé sur le cycle PDCA ». Le cours précise que « ces trois référentiels ne s'excluent pas : le NIST CSF offre une structure conceptuelle de haut niveau, le CIS des contrôles techniques opérationnels détaillés, et l'ISO 27001 un chemin vers une certification externe reconnue ». Nommer les cinq fonctions du NIST CSF dans leur ordre. Pourquoi une organisation qui se contenterait de l'un des trois référentiels, au choix, resterait-elle incomplètement outillée par rapport à une organisation combinant les trois — que perdrait-elle précisément en abandonnant chacun des deux autres ?
- (d) Le cours définit le triptyque CIA — « confidentialité (Confidentiality), intégrité (Integrity) et disponibilité (Availability) — les deux premières relevant de la sécurité de l'information proprement dite, la troisième de la continuité d'activité et donc de la résilience » — et distingue les contrôles « comportementaux (campagnes de sensibilisation, tests de phishing simulés, règles de conduite, sanctions) » des contrôles « techniques (architecture réseau, gestion des accès, pare-feux, chiffrement, détection de fuite de données, honeypots) ». Pour chacune des trois dimensions du CIA, donner un exemple d'incident qui l'affecterait spécifiquement sans nécessairement affecter les deux autres. Pourquoi le cours range-t-il la disponibilité dans un domaine différent (la continuité d'activité) plutôt que dans la seule sécurité de l'information, alors que les trois dimensions sont présentées ensemble sous un acronyme unique ?

Exercice 2 — Des indicateurs clés de risque au déroulement de l'attaque Equifax

- (a) Le cours propose des « KRI spécifiques à la sécurité de l'information » : « retard de correctifs de vulnérabilité, retard des tests d'intrusion, taux de résultats aux tests de phishing simulés, nombre de « récidivistes » ayant échoué à plusieurs tests de phishing dans des zones sensibles, taux de vacance dans les équipes de cybersécurité, ou encore nombre d'appareils ou de cartes d'accès

perdus ou volés », présentés comme « autant de signaux avancés d’une dégradation de la posture de sécurité, bien avant toute matérialisation en perte ». Classer ces six indicateurs en distinguant ceux qui mesurent une défaillance de processus technique (correctifs, tests d’intrusion) de ceux qui mesurent une défaillance humaine ou organisationnelle (phishing, récidivistes, vacance, appareils perdus). En quel sens précis un KRI est-il un « signal avancé » plutôt qu’une mesure de la perte elle-même : qu’observe-t-on avec un KRI qu’on ne pourrait pas observer en attendant la matérialisation d’un incident ?

- (b) Le cours relate que « le 10 mars 2017, des attaquants ont exploité une vulnérabilité connue du logiciel Apache Struts via le portail de contestation en ligne d’Equifax [...]. Pendant trois mois, ils sont restés non détectés au sein des systèmes d’Equifax, accédant à plusieurs bases de données et exfiltrant les noms, dates de naissance, numéros de sécurité sociale et informations de cartes bancaires de 147 millions de consommateurs américains. » Le cours ajoute qu’« Equifax a perdu près de 5 milliards de dollars de capitalisation boursière dans la semaine suivant l’annonce publique, sur un total de 15,5 milliards. » Calculer la part que représentent ces 5 milliards de dollars de perte dans la capitalisation boursière totale de 15,5 milliards, et énumérer les quatre catégories de données personnelles exfiltrées. Pourquoi le cours prend-il soin de préciser « pendant trois mois » avant de donner le nombre de consommateurs affectés : quel lien le cours établit-il implicitement entre la durée de l’intrusion non détectée et l’ampleur finale de la fuite ?
- (c) Le cours révèle que « dès 2015, un audit interne avait détecté un arriéré de 8 500 vulnérabilités non corrigées, révélant des faiblesses sévères du processus de gestion des correctifs — dont Equifax développait alors sa toute première politique formelle », et qu’« en mai 2016, un an avant la fuite majeure, le site W-2 Express d’Equifax avait déjà été piraté, exposant les données de 430 000 personnes », concluant que « ces signaux avant-coureurs n’ont pas suffi à corriger les déficiences structurelles avant l’attaque de 2017 ». En quoi l’arriéré de 8 500 vulnérabilités détecté en 2015 constitue-t-il un signal que les KRI du (a) — en particulier le « retard de correctifs de vulnérabilité » — auraient dû faire remonter bien avant l’audit ponctuel qui l’a révélé ? Pourquoi le piratage du site W-2 Express en mai 2016 constitue-t-il un « précédent ignoré » particulièrement aggravant, plutôt qu’un simple incident isolé sans lien avec la fuite de 2017 ?
- (d) Reprendre les six KRI du (a) et indiquer, pour chacun des cinq faiblesses structurelles présentées plus loin dans le chapitre (inventaire des actifs, gestion des correctifs, communication interne, certificat SSL, communication de crise externe), lequel de ces six KRI — s’il avait été suivi et remonté à temps — aurait pu signaler la faiblesse correspondante avant la matérialisation de l’attaque de mars 2017. Certaines des cinq faiblesses ont-elles un KRI dédié parmi les six proposés par le cours, et d’autres non ? Qu’est-ce que cela révèle sur les limites d’un dispositif de KRI, même bien conçu ?

Exercice 3 — Les cinq faiblesses structurelles d’Equifax et ses suites

- (a) Le cours identifie cinq faiblesses structurelles chez Equifax. Nommer précisément chacune des cinq, avec le fait ou le chiffre clé qui l’illustre selon le cours : l’absence d’inventaire (« délai réglementaire de 48 heures ») ; l’échec de gestion des correctifs (« disponible dès le 7 mars [...] distribué en interne à 400 employés — sans jamais être appliqué ») ; la communication interne défaillante (l’employé absent de la liste de diffusion, le manager qui « ne l’a pas relayée ») ; le certificat SSL expiré (détection retardée « jusqu’au 29 juillet ») ; et la communication de crise externe défaillante (annonce publique « six semaines après la découverte de la brèche »).
- (b) Le cours indique qu’« en juillet 2019, Equifax a accepté de payer jusqu’à 700 millions de dollars d’amendes et de compensations, dont 300 millions destinés aux consommateurs affectés », un événement ayant « entraîné la démission du directeur général, du RSSI et du directeur des systèmes d’information, ainsi que des enquêtes de plusieurs autorités fédérales américaines ». Calculer la part du règlement total de 700 millions de dollars qui ne revient pas directement aux consommateurs affectés. Pourquoi le cours mentionne-t-il la démission conjointe de trois dirigeants précis (directeur général, RSSI, directeur des systèmes d’information) plutôt qu’une simple mention générique de « départs à la direction » : que révèle le choix de ces trois fonctions

précises sur la nature des cinq faiblesses identifiées au (a) ?

- (c) Le cours rappelle que « le chapitre 4 avait présenté les «3R» de la communication de crise destinés à limiter les dommages réputationnels lors d'un événement de risque opérationnel majeur », et affirme que « le cas Equifax illustre a contrario les conséquences d'un défaut de leur application : une communication tardive et peu transparente a aggravé la perte de confiance déjà provoquée par la fuite elle-même, transformant un incident technique en crise de réputation durable ». Expliquer précisément ce que signifie « a contrario » dans ce contexte : le cas Equifax illustre-t-il les 3R en action, ou leur absence ? En quoi le délai de « six semaines » avant l'annonce publique (cinquième faiblesse du (a)) est-il en tension directe avec chacun des trois principes du regret, de la raison et du remède, tels que le cours les définit ?
- (d) Le cours conclut que le cas Equifax illustre « comment un événement de risque opérationnel majeur naît rarement d'une cause unique, mais de la conjonction de défaillances qui, prises isolément, auraient chacune pu être maîtrisée ». En reprenant les cinq faiblesses du (a), montrer au moins deux exemples précis d'enchaînement causal entre elles — c'est-à-dire un cas où une faiblesse a directement empêché la détection ou la correction d'une autre. Si une seule des cinq faiblesses avait été corrigée à temps (au choix), l'attaque de 147 millions de comptes aurait-elle nécessairement été évitée selon la logique du cours, ou seulement rendue moins probable ou moins grave ?

2 Exercice cumulatif (chapitres 8, 7, 6, 5, 4)

Exercice 4 — Le cas Equifax à la lumière des quatre chapitres précédents

- (a) Le chapitre 7 se réfère précisément sur l'annonce de ce chapitre : « les interconnexions avec les tiers [...] imposent un cadre contractuel et un droit d'audit dont l'application reste hétérogène d'une juridiction à l'autre — un chantier encore en construction que le chapitre suivant illustrera à travers le cas Equifax ». Le chapitre 7 y présente également le « vieillissement des correctifs de sécurité (patch ageing) » comme un « indicateur emblématique », en observant que « la plupart des juridictions se concentrent encore sur des indicateurs rétrospectifs [...] pertinents lorsque l'environnement est stable — ce qui n'est pas le cas face à des adversaires cyber qui adaptent continuellement leurs tactiques ». Ce chapitre reprend très exactement ce même indicateur sous le nom de « retard de correctifs de vulnérabilité » parmi ses KRI dédiés. Montrer que la deuxième faiblesse d'Equifax — le correctif « disponible dès le 7 mars [...] distribué en interne à 400 employés — sans jamais être appliqué » — est très exactement le scénario concret que le patch ageing du chapitre 7 est conçu pour prévenir en amont. Le chapitre 7 promettait une illustration par le cas Equifax : montrer précisément en quoi ce chapitre tient cette promesse, au-delà du seul patch ageing, en reliant le cas Equifax au thème plus large du chapitre 7 sur les « indicateurs prospectifs de résilience, encore peu harmonisés ».
- (b) Le chapitre 6, en énumérant la deuxième ligne de défense d'une grande banque, cite « un responsable de la sécurité de l'information (RSSI, voir chapitres 7-8) », et son étude de cas sur la Commonwealth Bank of Australia (CBA) documente « un cadre de gestion du risque opérationnel « meilleur sur le papier qu'en pratique » », ainsi qu'une « détection et [...] escalade tardives des incidents » et des « responsabilités mal définies ». Ce chapitre montre qu'Equifax « développait alors sa toute première politique formelle » de gestion des correctifs en 2015, une politique que la deuxième faiblesse identifiée révèle n'avoir jamais été appliquée en pratique. Montrer que la formule du chapitre 6 à propos de la CBA — un cadre « meilleur sur le papier qu'en pratique » — s'applique mot pour mot au cas Equifax de ce chapitre. Le chapitre 6 cite également une étude (Ellul et Yerramilli) selon laquelle une fonction risque forte et indépendante réduit le risque de queue : la troisième faiblesse de ce chapitre — l'employé absent de la liste de diffusion et le manager qui « ne l'a pas relayée » — est-elle un symptôme d'une fonction de sécurité de l'information faible au sens de cette étude, ou d'un problème d'un autre ordre (organisationnel plutôt qu'institutionnel) ? Justifier la distinction.

- (c) Le chapitre 5 rappelle une donnée statistique centrale : « les pertes les plus importantes, supérieures à 10 millions d’euros, ne représentent que 0,4 % du nombre d’occurrences mais concentrent 66,6 % de la sévérité totale », d’où le principe qu’« il n’y a pas de moyennes pertinentes en risque opérationnel ». Ce chapitre indique lui-même que sa section sur les KRI « prolonge le chapitre 5 sur la communication des risques », et rapporte une perte de « près de 5 milliards de dollars de capitalisation boursière » pour Equifax. Montrer que la perte de 5 milliards de dollars subie par Equifax illustre concrètement, à une tout autre échelle que les exemples du chapitre 5, le même principe de queue extrêmement épaisse : pourquoi un raisonnement fondé sur une perte « moyenne » d’incident de sécurité de l’information n’aurait manifestement rien pu prédire d’un événement de cette ampleur ? Par ailleurs, le chapitre 5 précise que, dans son « gâteau du reporting », seul un événement qui « révèle une faiblesse structurelle de contrôle affectant l’appétit pour le risque de l’organisation » justifie une remontée au conseil d’administration, sous forme de « conclusion » synthétique. L’arrière de 8 500 vulnérabilités détecté par l’audit interne de 2015 aurait-il dû, selon cette logique du chapitre 5, remonter jusqu’au conseil d’administration d’Equifax ? Justifier à partir de la citation du chapitre 5 reproduite ci-dessus.
- (d) Le chapitre 4 présente les « 3R » de la communication de crise — « le regret [...] la raison [...] le remède » — et les quatre niveaux de rigueur croissante pour tester un contrôle, de « l’auto-certification (ou enquête déclarative), [qui] offre l’assurance la plus faible », jusqu’à « la reperformance [...] la forme de test la plus exigeante ». Ce chapitre affirme explicitement que « le cas Equifax illustre a contrario les conséquences d’un défaut » d’application des 3R du chapitre 4. Montrer précisément, pour chacun des trois R, en quoi la cinquième faiblesse de ce chapitre (annonce publique « six semaines après la découverte de la brèche ») constitue une violation de ce principe particulier du chapitre 4. Par ailleurs, la diffusion interne du correctif Apache Struts « à 400 employés — sans jamais être appliqué » (deuxième faiblesse) ne reposait, de fait, que sur la simple diffusion d’une alerte, sans aucune vérification ultérieure. À quel niveau de rigueur des quatre définis par le chapitre 4 — probablement le plus faible, l’auto-certification — ce dispositif défaillant correspond-il, et quel aurait été, selon la logique du chapitre 4, l’apport d’un test de reperformance (par exemple une vérification technique directe de l’application du correctif sur un échantillon de systèmes) qui aurait pu prévenir la faille avant le 10 mars 2017 ?

3 Applications en sciences économiques

Exercice 5 — Chiffrer une matrice des risques de sécurité de l’information à quatre quadrants

Une compagnie d’assurance tient un registre annuel des incidents de sécurité de l’information, classés selon la matrice à quatre quadrants du cours (cause interne/externe, nature vol/perte). Sur l’exercice écoulé, le registre indique :

Quadrant	Incidents n	Perte moyenne (€)	Perte totale
Externe / Vol (piratage, ingénierie sociale)	14	180 000	
Externe / Perte (catastrophes, tiers)	5	95 000	
Interne / Vol (employé, départ)	9	60 000	
Interne / Perte (sauvegardes, erreurs d’envoi)	22	15 000	

- (a) Calculer la perte totale de chaque quadrant, le nombre total d’incidents et la perte totale du portefeuille. Calculer ensuite la part des incidents d’origine interne (quadrants Interne/Vol et Interne/Perte) dans le nombre total d’incidents, ainsi que la part de la perte totale imputable à ces mêmes quadrants internes. Comparer la première de ces deux parts à la statistique McAfee citée par le cours (« 43 % des fuites de données sont d’origine interne ») : le portefeuille de cette compagnie est-il plus ou moins exposé au risque interne, en nombre d’incidents, que ne le suggère cette moyenne sectorielle ?
- (b) Calculer la perte moyenne pondérée par incident sur l’ensemble du portefeuille (perte totale

divisée par le nombre total d'incidents). Calculer par ailleurs la part du quadrant Externe/Vol dans le nombre total d'incidents, puis sa part dans la perte totale. Ces deux parts sont-elles proches, ou le quadrant Externe/Vol concentre-t-il une part de la perte disproportionnée par rapport à sa part du nombre d'incidents? Qu'est-ce que cet écart illustre quant à la pertinence d'un raisonnement fondé sur la seule perte moyenne pondérée calculée plus haut?

- (c) La compagnie a fixé un indicateur clé de risque interne : si le quadrant Interne/Perte (sauvegardes, erreurs d'envoi) dépasse 30 % du nombre total d'incidents enregistrés, une revue obligatoire des procédures de sauvegarde et de prévention de fuite de données (DLP) est déclenchée. Calculer la part de ce quadrant dans le nombre total d'incidents et déterminer si la revue est déclenchée. Calculer également la part de ce même quadrant dans la perte totale : ce quadrant, bien que potentiellement le plus fréquent, est-il également le plus coûteux en moyenne?
- (d) La compagnie envisage un investissement de 50 000 € en contrôles comportementaux ciblés (formation renforcée, tests de phishing simulés supplémentaires) sur les deux quadrants de vol intentionnel (Externe/Vol et Interne/Vol), qu'elle estime pouvoir réduire de 30 % le nombre d'incidents dans ces deux quadrants, sans changer leur perte moyenne unitaire. Calculer le nouveau nombre d'incidents et la nouvelle perte totale pour chacun de ces deux quadrants, l'économie totale ainsi réalisée, le bénéfice net de l'investissement, et le ratio bénéfice/coût. Calculer enfin la nouvelle perte totale du portefeuille après cet investissement.

Exercice 6 — Règlement post-incident et coût du délai de détection (cas Equifax), chiffré

Une agence d'évaluation de crédit fictive, NordicScore, subit une violation de données affectant 60 millions de clients. Un régulateur lui impose un règlement total de 250 millions de dollars, dont 120 millions destinés directement à l'indemnisation des consommateurs affectés, le solde couvrant amendes et remédiation. Sa capitalisation boursière avant l'incident était de 8 milliards de dollars; elle en perd 28 % dans la semaine suivant l'annonce publique.

- (a) Calculer la part du règlement total qui ne revient pas directement aux consommateurs. Calculer l'indemnisation moyenne par consommateur affecté (règlement destiné aux consommateurs divisé par le nombre de clients touchés). Un plancher réglementaire théorique impose une indemnisation moyenne d'au moins 1,50 \$ par consommateur affecté : ce plancher est-il respecté?
- (b) Calculer la perte de capitalisation boursière en dollars. Calculer le ratio de cette perte de capitalisation au règlement total imposé par le régulateur. Ce ratio est-il cohérent, en ordre de grandeur, avec celui observé dans le cas réel d'Equifax (perte boursière d'environ 5 milliards de dollars pour un règlement de 700 millions, cf. le cours) ?
- (c) Le comité des risques envisage un programme de remédiation (inventaire exhaustif des actifs et automatisation de la gestion des correctifs) coûtant 40 millions de dollars sur 3 ans, réduisant la probabilité annuelle d'un incident de cette nature de 8 % à 1,5 %. En prenant comme coût total d'un incident la somme du règlement et de la perte de capitalisation boursière calculée au (b), calculer la perte annuelle attendue avant et après cet investissement, le bénéfice annuel qui en résulte, le coût annualisé de l'investissement, le bénéfice net annuel, et le ratio bénéfice/coût. L'investissement est-il justifié économiquement ?
- (d) Une étude interne estime qu'à défaut de correction, chaque semaine de retard dans la détection d'une intrusion ajoute linéairement 3 % à un coût de base de 900 millions de dollars (frais techniques et juridiques minimaux hors amplification liée au délai), sans effet de composition. Calculer le coût total pour un délai de détection de 90 jours (arrondi à 12,857 semaines, sur la base de semaines de 7 jours) et pour un délai de 14 jours (2 semaines). Calculer l'économie réalisée en ramenant le délai de détection de 90 à 14 jours, en dollars et en pourcentage relatif du coût au délai de 90 jours. Ce résultat est-il cohérent avec le rôle attribué par le cours au certificat SSL expiré d'Equifax, qui a « retardé la détection de l'intrusion jusqu'au 29 juillet » ?